Módulo Afondamento nas competencias profesionais (GS)
Unidad 3. Seguridad de sitios web. Herramientas de IA para desarrollo web.

Actividad 3.1. Identificación y corrección de vulnerabilidades en una aplicación web

Tarea práctica:
Identificación y corrección de vulnerabilidades en una aplicación web

Una pequeña empresa ha desarrollado una aplicación web básica para gestionar usuarios y comentarios en su página.
Sin embargo, el código presenta **varias vulnerabilidades de seguridad** que pueden ser explotadas por atacantes.

Como desarrolladores web, vuestro trabajo consiste en:

- **Analizar la aplicación**
- **Identificar vulnerabilidades**
- **Explotarlas de forma controlada**
- **Proponer y aplicar soluciones**

Objetivos de aprendizaje

- Comprender vulnerabilidades web comunes.
- Identificar problemas de seguridad en código real.
- Aplicar buenas prácticas de desarrollo seguro.
- Conocer herramientas básicas de análisis de seguridad.

Tecnologías utilizadas

La práctica se realizará con:
- **HTML**
- **PHP**
- **MySQL / MariaDB**
- Navegador web
- Herramientas del navegador (DevTools)
  Opcional:
  - **OWASP ZAP**
  - **OWASP Top 10**

Aplicación vulnerable (ejemplo simplificado)

login.php

```
<?php
$conn = new mysqli("localhost","root","","empresa");

$user = $_POST['user'];
$pass = $_POST['pass'];

$query = "SELECT * FROM usuarios WHERE usuario='$user' AND
password='$pass'";
$result = $conn->query($query);

if($result->num_rows > 0){
    echo "Bienvenido ".$user;
}else{
    echo "Login incorrecto";
}
?>
```

comentarios.php

```
<?php
$comentario = $_POST['comentario'];

echo "<h3>Comentario enviado:</h3>";
echo $comentario;
?>
```

Actividades a realizar:

Actividad 1 — Análisis de vulnerabilidades

Analiza el código y responde las siguientes preguntas:

1. ¿Qué vulnerabilidad aparece en el login?
2. ¿Qué vulnerabilidad aparece en el sistema de comentarios?
3. ¿Qué consecuencias puede tener cada una?

Actividad 2 — Explotación controlada

1. SQL Injection

Intenta iniciar sesión usando:

```
' OR '1'='1
```

Pregunta:

- ¿Se puede acceder sin contraseña?
- Explica por qué ocurre.

2. Cross Site Scripting (XSS)

Introduce el siguiente comentario:

```
<script>alert("Ataque XSS")</script>
```

Pregunta:
- ¿Qué ocurre en la página?
- ¿Por qué es peligroso?

Corrección de vulnerabilidades

Corregir SQL Injection

Usar **consultas preparadas**:

```
$stmt = $conn->prepare("SELECT * FROM usuarios WHERE usuario=?
AND password=?");
$stmt->bind_param("ss",$user,$pass);
$stmt->execute();
```

Corregir XSS

Escapar la salida:

```
echo htmlspecialchars($comentario, ENT_QUOTES, 'UTF-8');
```

Actividad final

Deberás entregar un informe con:

1. Vulnerabilidades detectadas
2. Pruebas realizadas
3. Código corregido
4. Explicación de cómo evitar estos problemas en el futuro

Vulnerabilidades a investigar (investigación)

Investiga brevemente estas vulnerabilidades del **Top 10 de OWASP** y explica en qué consisten:

- Inyección SQL
- XSS
- Control de acceso roto
- Exposición de datos sensibles

Más información:

- **OWASP ZAP**: https://www.incibe.es/incibe-cert/seminarios-web/uso-owasp-zap
- **OWASP Top 10:** https://owasp.org/www-project-top-ten/